Auditoría básica de seguridad con Nmap

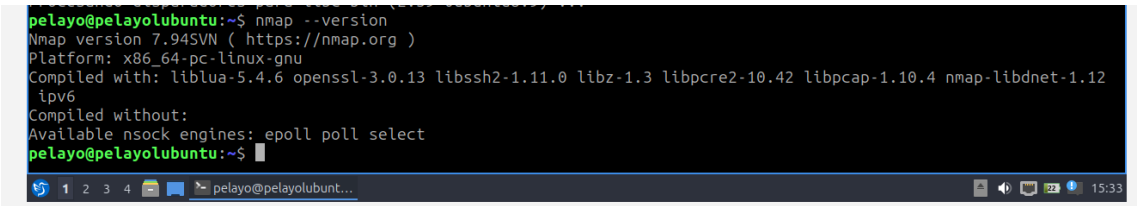
Reconocimiento, análisis de servicios y propuesta de contramedidas

Pelayo Fernández Ojanguren

Módulo: Seguridad y alta disponibilidad

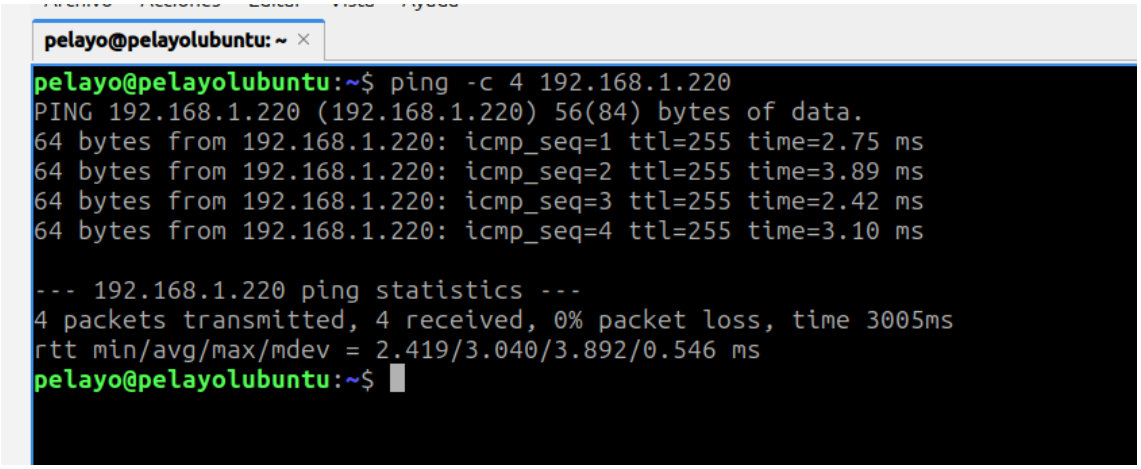
1. **Instalación y verificación de Nmap**

- Actualizamos la lista de paquetes en la máquina atacante, en este caso Lubuntu, con el comando *sudo apt update* y a instalar la herramienta de auditoría nmap con *sudo apt install nmap -y*. Una vez completada la instalación, validamos su correcta integración al sistema:



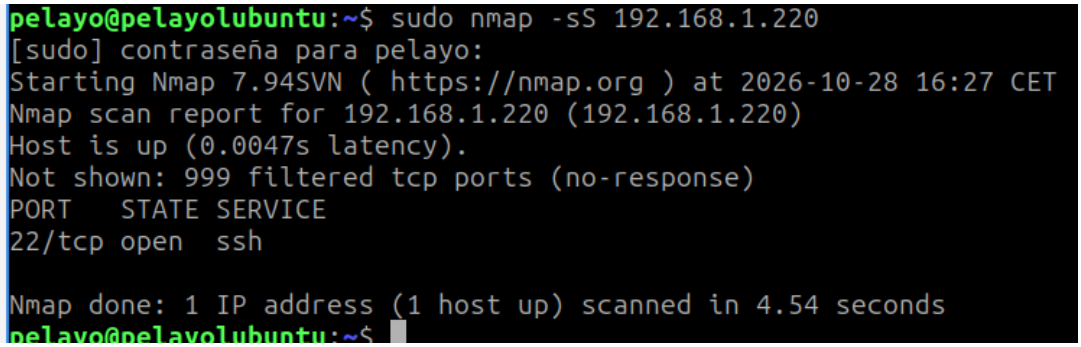
2. **Identificación del objetivo**

- Una vez identificamos la dirección IP del servidor objetivo (En mi caso ejecute el comando *ip a* en el servidor objetivo), procedemos a comprobar la conectividad desde la máquina atacante con un ping. Vemos que no se ha perdido ningún paquete en el proceso, por tanto, la conexión ha sido exitosa.



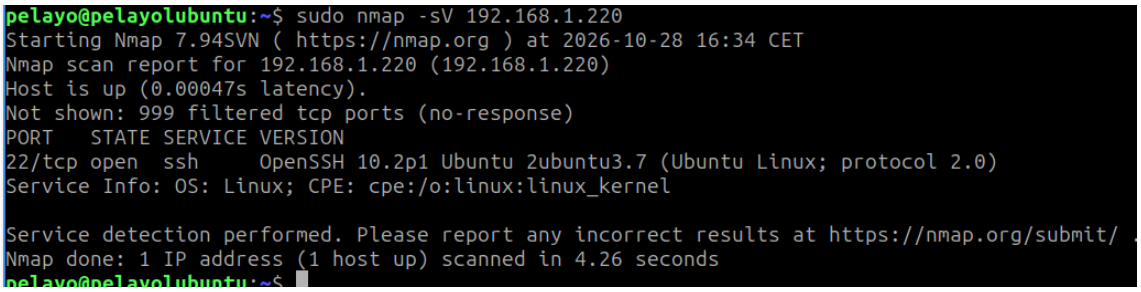
3. **Escaneo básico de puertos**

- Escaneo SYN básico:



Ejecutamos un escaneo SYN mediante privilegios administrativos sobre los 1000 puertos TCP más comunes. Se ha detectado que el puerto 22/tcp está abierto, el cual corresponde con el servicio ssh. Los otros 999 puertos no han dado respuesta, lo que significa que el cortafuegos perimetral o local descartaría los paquetes.

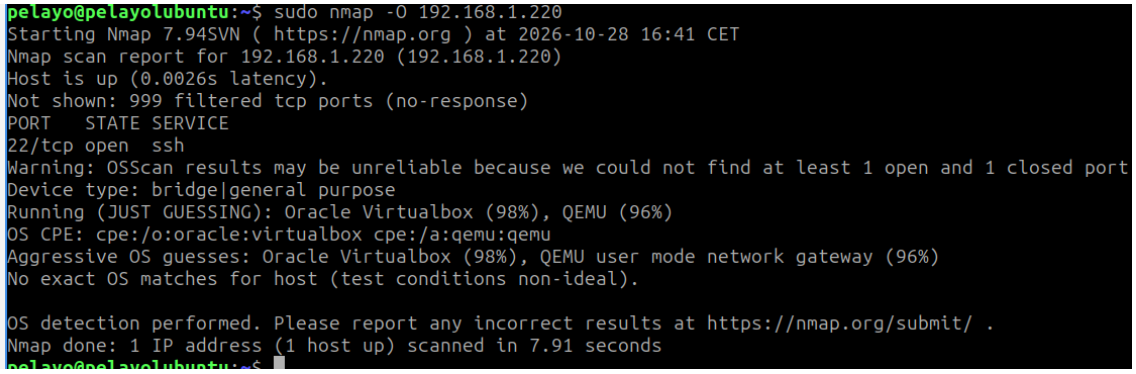
- Escaneo de detección de servicios y versiones:



En el puerto 22/tcp se detectó el servicio de acceso remoto seguro OpenSSH con la versión exacta *"OpenSSH 10.2p1 Ubuntu 2ubuntu3.7"*.

Debajo de eso, podemos ver que el sistema operativo de la máquina es Linux derivado de Ubuntu.

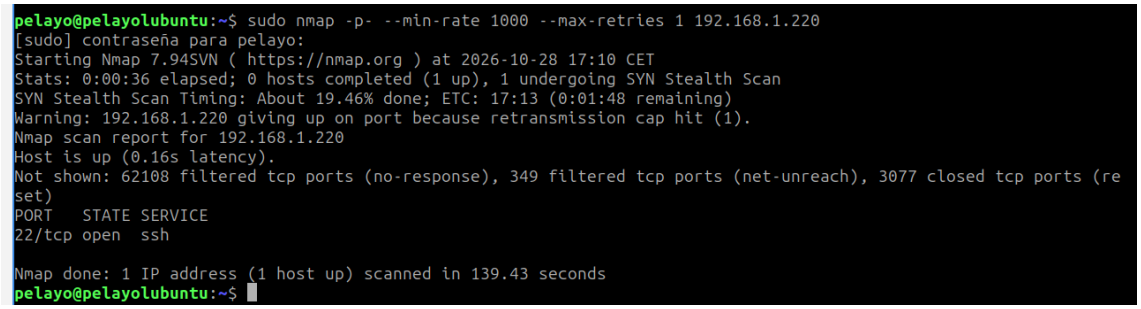
- Detección del sistema operativo:



Limitación del sondeo → nmap muestra un aviso de fiabilidad ya que necesita comparar el comportamiento ante un puerto abierto y uno cerrado. El resto de los puertos están en estado filtrado, por eso, no puede confirmar con certeza absoluta el sistema operativo.

Aun así, clasifica al dispositivo como un hipervisor con un 98% de probabilidad de que sea Oracle VirtualBox.

- Escaneo completo de todos los puertos:



Se ejecuto una auditoría completa sobre la totalidad de puertos TCP. Para optimizar el tiempo de ejecución en un entorno con paquetes filtrados, se fijó la tasa mínima de sondeo a 1000 y la retransmisión por puerto a 1 reintento.

Con esta configuración, se confirmó que el único servicio detectado accesible es el puerto **22/tcp** que está **abierto** y corresponde al servicio ssh. Los demás puertos:

- 62108 puertos filtrados y sin respuesta, descarte silencioso de paquetes.
- 349 puertos filtrados pero inalcanzables.
- 3077 puertos cerrados al devolver un paquete TCP RST.

4. Análisis de los resultados

- Servicio asociado

SSH → versión detectada *OpenSSH 10.2p1 Ubuntu 2ubuntu3.7*

- ¿Para qué se utiliza este servicio?

Es un protocolo de red diseñado para la administración remota segura de servidores. Los administradores pueden iniciar sesión de forma cifrada mediante línea de comandos, ejecutar órdenes en el sistema operativo y transferir archivos con confidencialidad e integridad. Este sustituye al protocolo Telnet ya que este es inseguro al no estar cifrado.

- Posibles vulnerabilidades asociadas

Ataques de fuerza bruta o diccionario → Esta expuesto a servicio de autenticación, por tanto, un atacante puede hacer intentos continuos para adivinar las credenciales del usuario y contraseña si no existen límites de intentos.

Relacionado con el anterior, el acceso directo a un usuario root si la directiva permite el inicio de sesión directo como superusuario. De esta manera, el atacante solo deberá adivinar la contraseña y una vez dentro tendrá control total sobre el servidor al ser un usuario con privilegios. Podría borrar datos o robarlos, así como apagar el servidor.

Vulnerabilidades del software, como pueden ser fallos específicos en versiones desactualizadas del paquete OpenSSH, podrían permitir ejecución remota de código si el sistema no se parchea con regularidad.

- Nivel de riesgo

En una red local, estaríamos hablando de un riesgo **medio**, si se expusiera a internet seríaudita riesgo alto. SSH es un protocolo robusto y de cifrado, pero si las credenciales del usuario son vulnerables o la configuración de autenticación débil, el atacante podría obtener acceso de terminal al servidor comprometiendo el entorno.

5. Propuesta de contramedidas

Para proteger el servicio ssh expuesto en el puerto 22 y mitigar los vectores de entrada identificados:

- Deshabilitar el inicio de sesión directo como root → ***PermitRootLogin no***. Esto obliga a cualquier administrador a acceder primero con una cuenta de usuario sin privilegios y escalar más tarde a un superusuario mediante *sudo*. Evita que un atacante ataque directamente la cuenta de mayor rango.
- Implementar protección contra fuerza bruta → Instalar herramientas de monitorización como Fail2ban. Analizan registros del demonio SSH y bloquean temporalmente a nivel de cortafuegos la IP de cualquier host tras un numero consecutivo de intentos de autenticación fallidos.
- Restricción de acceso en el cortafuegos (filtrado por IP) → configurar el firewall local de manera que solo acepte conexiones al puerto SSH de rangos de direcciones IP autorizados, descartando las peticiones del resto de red.
- Por último, mantener el paquete **openssh-server** actualizado para eliminar posibles vulnerabilidades conocidas para la versión en uso.

6. Inventario de servicios

Puerto	Servicio	Versión detectada	Nivel de riesgo	Medidas propuestas
22/tcp	SSH	OpenSSH 10.2p1 Ubuntu 2ubuntu3.7 (protocol 2.0)	Medio (red local)	Deshabilitar el acceso directo a root, instalar herramienta de monitorización para bloquear IPs tras intentos fallidos y limitar acceso en firewall a IPs autorizadas.

Conclusión.

- Hemos comprobado que la superficie de ataque es reducida, tras el análisis de todos los puertos revela que el servidor tiene un perímetro bastante restringido, localizando el único vector de entrada en el puerto 22.
- En consecuencia, al tener solo un único vector de entrada, hay que asegurar el bastionado de este a pesar de que su versión de OpenSSH sea moderna. Esto podemos conseguirlo mediante la deshabilitación del acceso directo a la cuenta root, la instalación de herramientas de monitorización para bloquear temporalmente IPs de posibles atacantes y limitar el firewall a un rango de IPs autorizadas.
- El descarte de paquetes silencioso en la mayoría de los puertos demuestra la eficacia de las políticas de filtrado y de las reglas restrictivas del cortafuegos.
- La combinación escalonada de sondeos con Nmap (conectividad ICMP, SYN, detección de versiones y barrido completo del espectro de puertos) es la metodología estándar más eficiente de auditar un equipo. Optimiza los tiempos de análisis, minimiza el tráfico innecesario en la red y asegura una visibilidad completa del sistema.